

통 보

14

제 목 IT 시스템 권한 관리 미흡

관 계 기 관 ○○○○○○(주)

구 분 총무

내 용

1. 업무개요

○○○○○○(주)은 원활한 업무 수행을 위해 ▲▲급여 경영정보시스템(ERP), 그룹웨어 시스템, 보안 정보관리 모니터링시스템과 같은 IT 시스템을 구축하여 운영하고 있고, 그룹웨어 및 ERP 시스템 사용 시 내부 정보에 대한 임직원의 책임 의식 제고 및 권한 남용 등 보안사고에 대응하기 위해 「전산시스템 접근 권한 관리 계획」⁵⁰⁾(이하 “관리계획”이라 한다)을 2025. 9. 18. 수립하였다.

2. 관련법령 및 판단기준

감사원은 공공부문에서 기관의 효과적인 내부통제시스템 설계·운영을 지원 하기 위해 「공공부문 내부통제 가이드라인」⁵¹⁾(이하 “가이드라인”이라 한다)을 배포 하였고, ○○○○○○(주)은 공직유관단체⁵²⁾로서 이를 참고하여 기관의 목표 달성에 도움이 되도록 기관 내 효과적인 내부통제시스템을 구축하고 운영하여야 한다.

50) 시스템 계정 등록 관리, 그룹웨어 문서 열람 권한 부여 기준, 권한부여 절차, 접근 권한 자체 점검방안 등을 수록하였음

51) 공공부문 내부통제업무 지원을 위한 안내자료로서 2023. 10. 24.에 배포

52) ○○○○○○(주)은 2020. 7. 공직유관단체로 지정되었음

가이드라인 원칙 11⁵³⁾에 따르면 최고관리자(사장)는 직원의 입·퇴사 또는 전보 발생 시 권한을 신속하게 수정·회수하고, 직급 및 담당업무, 정보자원 중요도 등을 고려하여 IT 시스템을 사용하는 직원에게 적절한 접근권한⁵⁴⁾을 부여하여 시스템 내 데이터의 부적정한 수정이나 삭제 위험으로부터 정보를 보호하여야 한다.

한편 ○○○○○○○(주)의 관리계획에 따르면 IT 시스템 담당자는 원활한 시스템 관리를 위해 시스템별 권한 보유대장을 신설하여 변동사항(신규 권한 부여·수정·삭제 등) 발생 시 해당 대장을 최신화하여 관리하고 권한을 부여받는 당사자에게는 보안 서약서를 징구하도록 하고 있다.

또한 시스템 권한 보유대장을 활용하여 그룹웨어 및 ERP 시스템 접근 권한 부여의 적정성(권한 오남용 여부 등)을 반기 1회 이상 의무적으로 점검하도록 하고 있으며, 점검결과 권한 부여에 이상이 있을 경우 관련자의 권한을 즉시 삭제하는 등의 조치를 하도록 하고 있다.

3. 감사결과 확인된 문제점

그런데 감사일 현재(2025. 10. 28.) 시스템 권한 보유대장을 확인한 결과, 기존에 그룹웨어 및 ERP 시스템을 사용 중인 인원·계정에 대해서는 대장을 작성하지 않고 있었고, 관리계획 수립 이후에 신규로 부여한 인원·계정에 대해서만 수기로 작성하여 관리하고 있었으며, 보안서약서 징구 역시 관리계획 수립 이후 신규로 권한을 신청한 인원에게 대해서만 징구하고 있었다.

53) 「공공부문 내부통제 가이드라인」 원칙 11. IT 시스템에 대한 통제활동을 개발한다.

54) 실제 업무분장과 IT 시스템 권한이 일치하도록 접근권한 부여

관계기관 의견 및 검토결과 ○○○○○○○(주)은 IT 시스템 관리를 위해 특정 감사 이전에 선제적으로 제도 기반을 마련하면서 관리계획을 수립한 것으로, 이를 적극행정으로 인정을 요청하면서 향후 시스템 내부통제 강화를 위해 권한 관리 모니터링 시스템을 개발하여 관리 효율성을 제고할 계획이라고 하였다.

담당부서의 내부통제를 위한 관리계획 수립에 대한 노력은 인정하나, 관리 계획에 따른 준수사항을 충분히 시행하고 있지는 않았으므로 이를 시정토록 통보함이 타당하다.

조치할 사항 ○○○○○○○(주) 대표이사는 IT 시스템을 사용하는 기존 직원을 포함하여 보안서약서 징구 및 시스템 권한 보유대장을 작성·관리하여 주기적으로 적정성을 점검하는 등 IT 시스템 관련 통제활동을 철저히 하시기 바랍니다. (통보)